

ĐẠI HỌC QUỐC GIA TP.HCM

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN



**ĐỒ ÁN MÔN HỌC
AN TOÀN MẠNG**

**BÁO CÁO HƯỚNG DẪN CẤU HÌNH HỆ THỐNG MẠNG
BLUE TEAM**

BLUE TEAM

Giảng viên hướng dẫn – TS. Lê Kim Hùng

Sinh viên thực hiện:

23520552 – Phan Cảnh Đăng Huân
23520479 – Lê Đình Hiếu

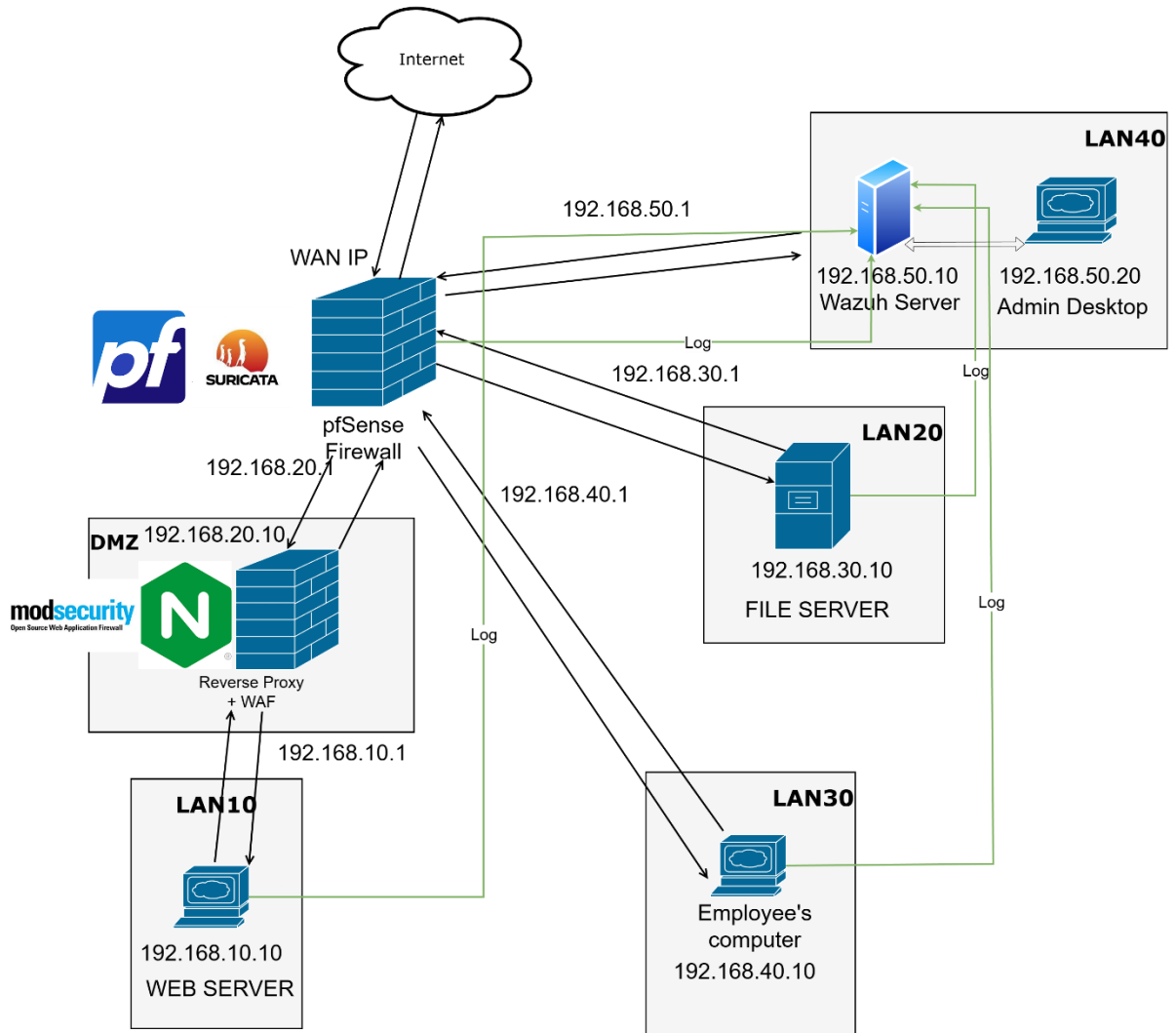
Mục lục

1. KIẾN TRÚC HỆ THỐNG	4
2. CÁC CẤU HÌNH LIÊN QUAN ĐẾN IP VÀ VMWARE	5
WAN	5
DMZ.....	6
LAN10.....	7
LAN20.....	8
LAN30.....	9
LAN40.....	10
3. CÁC CẤU HÌNH CHUNG.....	12
System Hardening	12
Cấu hình múi giờ	13
Cấu hình rootcheck để phát hiện rootkit, trojan, backdoor và các dấu hiệu hệ thống bị xâm phạm.	13
Cấu hình FIM	13
Cấu hình tài khoản IT Support.....	14
4. PFSENSE	16
Suricata	16
Rules.....	18
WAN	18
LAN10	19
DMZ.....	20
LAN30	21
LAN40.....	22
Aliases	22
Hosts.....	23
Alias đại diện cho Networks.....	23
5. DMZ (Reverse Proxy + WAF).....	23
Mục tiêu	23
Tạo và config DMZ.....	23
Cài Nginx Reverse Proxy trong DMZ	25
Cấu hình Reverse Proxy.....	25
Ẩn thông tin máy chủ	26

Kích hoạt ModSecurity WAF	26
Chặn các đường dẫn nhạy cảm	26
Cấu hình Proxy và tình chỉnh luật	26
Xử lý báo động giả.....	27
6. LAN10 (WEB SERVER).....	27
Mục tiêu	27
Tạo và config LAN10.....	27
Cài đặt Nginx	28
Gỡ user khỏi nhóm Docker:	28
Đóng gói Image ra file (Backup)	28
Bật users-remap để ánh xạ (remap) UID/GID root của container sang một UID/GID không đặc quyền trên máy host	28
7. LAN20 (FILE SERVER)	29
Tạo và config LAN20.....	29
Cài và cấu hình Samba	29
Cài đặt ClamAV.....	30
Chuẩn bị thư mục Log cho ClamAV	30
Cấu hình Lịch trình	30
Cấu hình Backup tự động.....	31
Tạo Tài khoản người dùng	34
Cấu hình Samba.....	35
Tắt tính năng Guest và ép buộc xác thực.....	35
Data-in-Transit Encryption	36
8. LAN30 (EMPLOYEE COMPUTER).....	37
Tạo và config LAN30.....	37
Cài smbclient	37
9. LAN40 (WAZUH + ADMIN DESKTOP)	38
Tạo và config LAN40.....	38
Wazuh-Agents	38
Admin Desktop.....	39

1. KIẾN TRÚC HỆ THỐNG

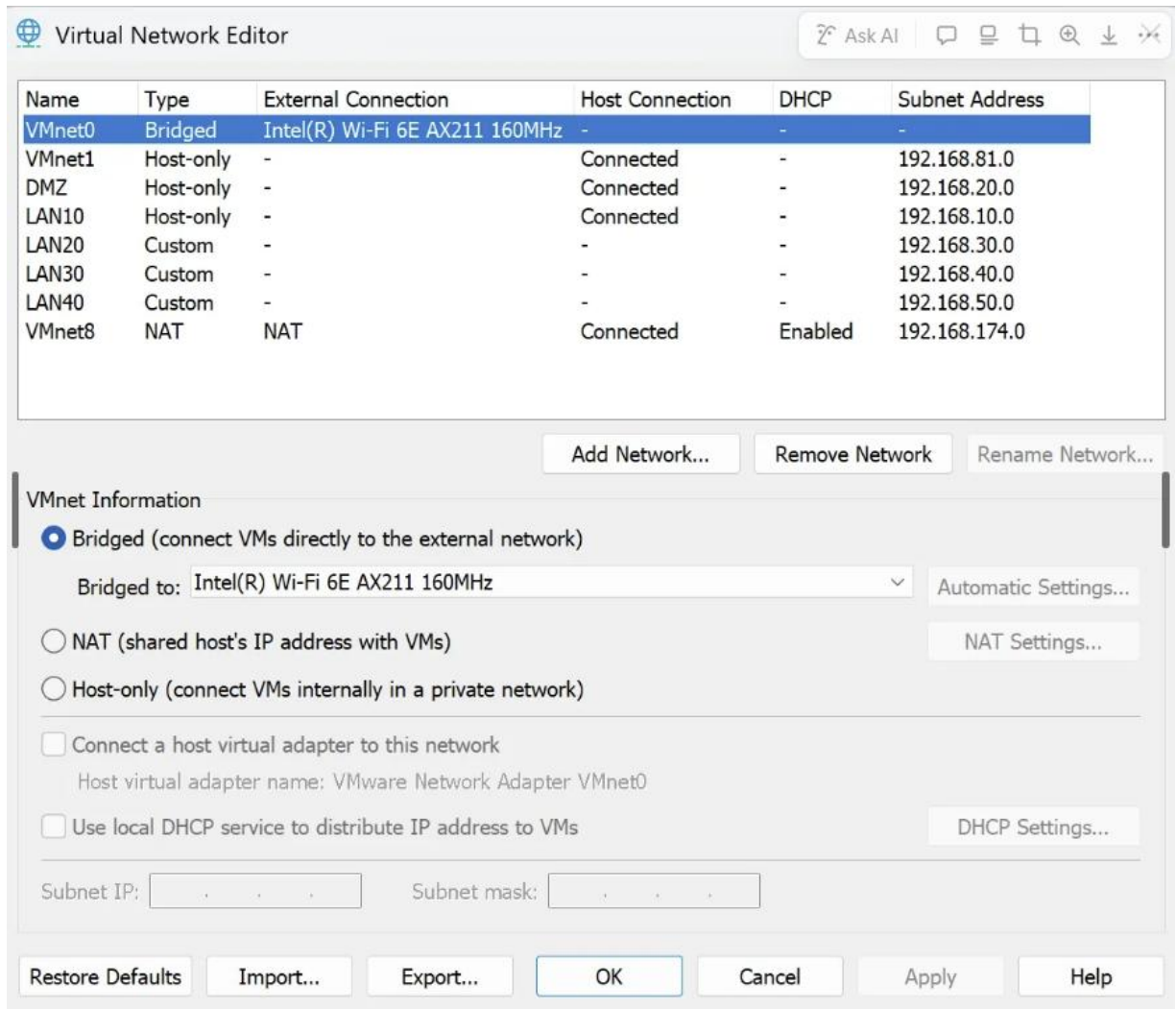
Tên	Chế độ	Dải IP	Mục đích
VMnet0	Bridged	do DHCP cấp	WAN
VMnet2	Host-only	192.168.20.0/24	DMZ
VMnet3	Host-only	192.168.10.0/24	LAN10
VMnet4	Host-only	192.168.30.0/24	LAN20
VMnet5	Host-only	192.168.40.0/24	LAN30
VMnet6	Host-only	192.168.50.0/24	LAN40



2. CÁC CẤU HÌNH LIÊN QUAN ĐẾN IP VÀ VMWARE

WAN

WAN Interface được gán là Bridged Adapter, để dễ dàng cho các thành viên kết nối nếu cùng Wifi.



DMZ

DMZ bao gồm Ubuntu Server 22.04 LTS có Nginx và WAF sử dụng Host-only, với dải IP là 192.168.20.0/24

Virtual Network Editor

Ask AI

Name	Type	External Connection	Host Connection	DHCP	Subnet Address
VMnet0	Bridged	Intel(R) Wi-Fi 6E AX211 160MHz	-	-	-
VMnet1	Host-only	-	Connected	-	192.168.81.0
DMZ	Host-only	-	Connected	-	192.168.20.0
LAN10	Host-only	-	Connected	-	192.168.10.0
LAN20	Custom	-	-	-	192.168.30.0
LAN30	Custom	-	-	-	192.168.40.0
LAN40	Custom	-	-	-	192.168.50.0
VMnet8	NAT	NAT	Connected	Enabled	192.168.174.0

Add Network...
 Remove Network
 Rename Network...

VMnet Information

☐ Bridged (connect VMs directly to the external network)

Bridged to: Intel(R) Wi-Fi 6E AX211 160MHz
 Automatic Settings...

☐ NAT (shared host's IP address with VMs)
 NAT Settings...

☒ Host-only (connect VMs internally in a private network)

☒ Connect a host virtual adapter to this network

Host virtual adapter name: VMware Network Adapter VMnet2

☐ Use local DHCP service to distribute IP address to VMs
 DHCP Settings...

Subnet IP: 192 . 168 . 20 . 0
 Subnet mask: 255 . 255 . 255 . 0

Restore Defaults
 Import...
 Export...
 OK
 Cancel
 Apply
 Help

LAN10

LAN10 bao gồm Web Server, gán với Host-only, có dải IP 192.168.10.0/24

Virtual Network Editor
 ✕

Name	Type	External Connection	Host Connection	DHCP	Subnet Address
VMnet0	Bridged	Intel(R) Wi-Fi 6E AX211 160MHz	-	-	-
VMnet1	Host-only	-	Connected	-	192.168.81.0
DMZ	Host-only	-	Connected	-	192.168.20.0
LAN10	Host-only	-	Connected	-	192.168.10.0
LAN20	Custom	-	-	-	192.168.30.0
LAN30	Custom	-	-	-	192.168.40.0
LAN40	Custom	-	-	-	192.168.50.0
VMnet8	NAT	NAT	Connected	Enabled	192.168.174.0

Add Network...
Remove Network
Rename Network...

VMnet Information

☐ Bridged (connect VMs directly to the external network)

Bridged to: Intel(R) Wi-Fi 6E AX211 160MHz
Automatic Settings...

☐ NAT (shared host's IP address with VMs)
NAT Settings...

☒ Host-only (connect VMs internally in a private network)

☒ Connect a host virtual adapter to this network

Host virtual adapter name: VMware Network Adapter VMnet3

☐ Use local DHCP service to distribute IP address to VMs
DHCP Settings...

Subnet IP: 192 . 168 . 10 . 0
Subnet mask: 255 . 255 . 255 . 0

Restore Defaults
Import...
Export...
OK
Cancel
Apply
Help

LAN20

LAN20 gồm File Server, cấu hình Host-only, với dải IP 192.168.30.0/24

Virtual Network Editor

Name	Type	External Connection	Host Connection	DHCP	Subnet Address
VMnet0	Bridged	Intel(R) Wi-Fi 6E AX211 160MHz	-	-	-
VMnet1	Host-only	-	Connected	-	192.168.81.0
DMZ	Host-only	-	Connected	-	192.168.20.0
LAN10	Host-only	-	Connected	-	192.168.10.0
LAN20	Custom	-	-	-	192.168.30.0
LAN30	Custom	-	-	-	192.168.40.0
LAN40	Custom	-	-	-	192.168.50.0
VMnet8	NAT	NAT	Connected	Enabled	192.168.174.0

Add Network... Remove Network Rename Network...

VMnet Information

☐ Bridged (connect VMs directly to the external network)
 Bridged to: Intel(R) Wi-Fi 6E AX211 160MHz Automatic Settings...

☐ NAT (shared host's IP address with VMs) NAT Settings...

☒ Host-only (connect VMs internally in a private network)

☐ Connect a host virtual adapter to this network
 Host virtual adapter name: VMware Network Adapter VMnet4

☐ Use local DHCP service to distribute IP address to VMs DHCP Settings...

Subnet IP: 192 . 168 . 30 . 0 Subnet mask: 255 . 255 . 255 . 0

Restore Defaults Import... Export... OK Cancel Apply Help

LAN30

LAN30 là vùng mạng dành cho nhân viên, được cấu hình Host-only với dải IP 192.168.40.0/24

Virtual Network Editor

Name	Type	External Connection	Host Connection	DHCP	Subnet Address
VMnet0	Bridged	Intel(R) Wi-Fi 6E AX211 160MHz	-	-	-
VMnet1	Host-only	-	Connected	-	192.168.81.0
DMZ	Host-only	-	Connected	-	192.168.20.0
LAN10	Host-only	-	Connected	-	192.168.10.0
LAN20	Custom	-	-	-	192.168.30.0
LAN30	Custom	-	-	-	192.168.40.0
LAN40	Custom	-	-	-	192.168.50.0
VMnet8	NAT	NAT	Connected	Enabled	192.168.174.0

VMnet Information

☐ Bridged (connect VMs directly to the external network)
 Bridged to: Intel(R) Wi-Fi 6E AX211 160MHz

☐ NAT (shared host's IP address with VMs)

☒ Host-only (connect VMs internally in a private network)

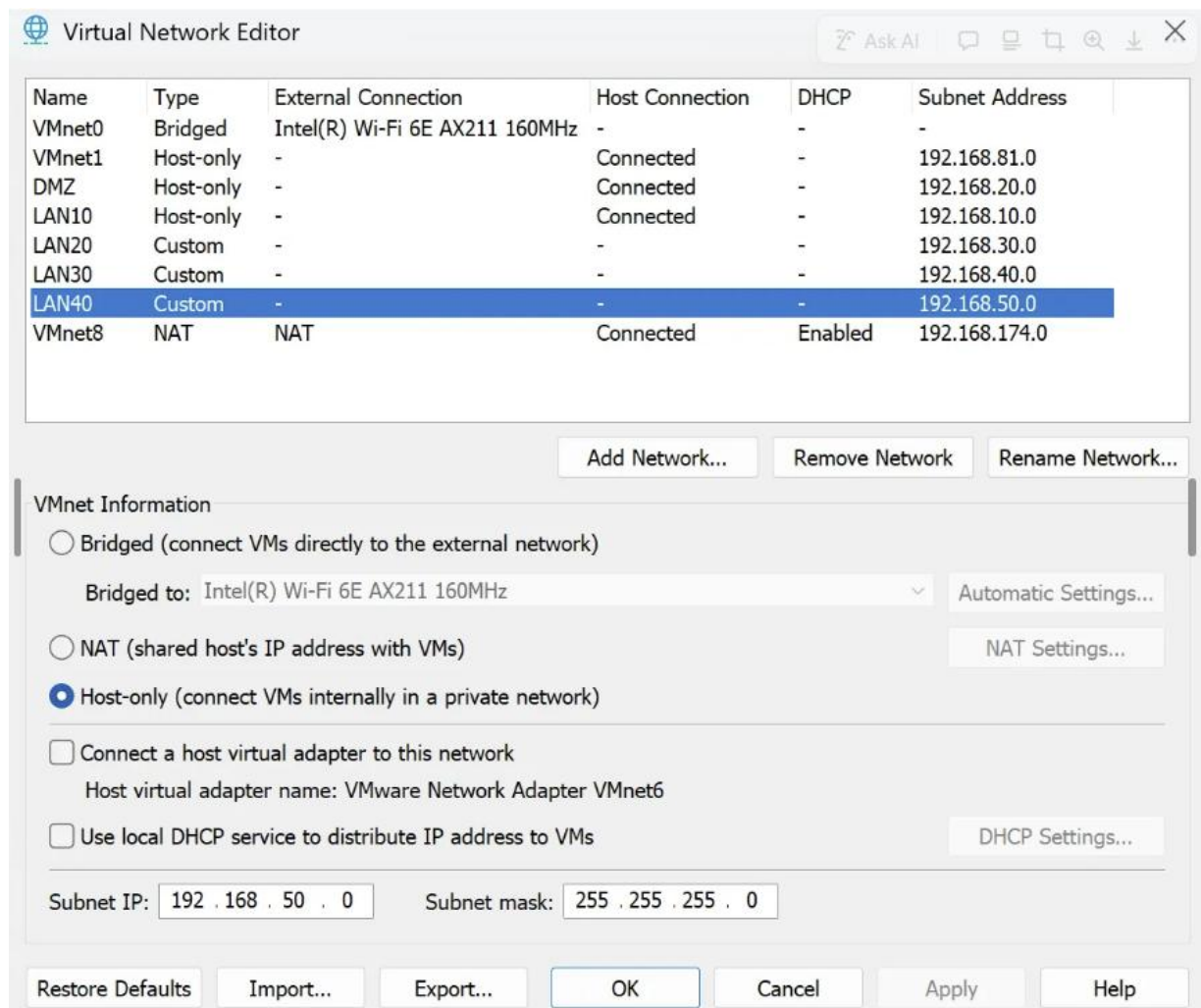
☐ Connect a host virtual adapter to this network
 Host virtual adapter name: VMware Network Adapter VMnet5

☐ Use local DHCP service to distribute IP address to VMs

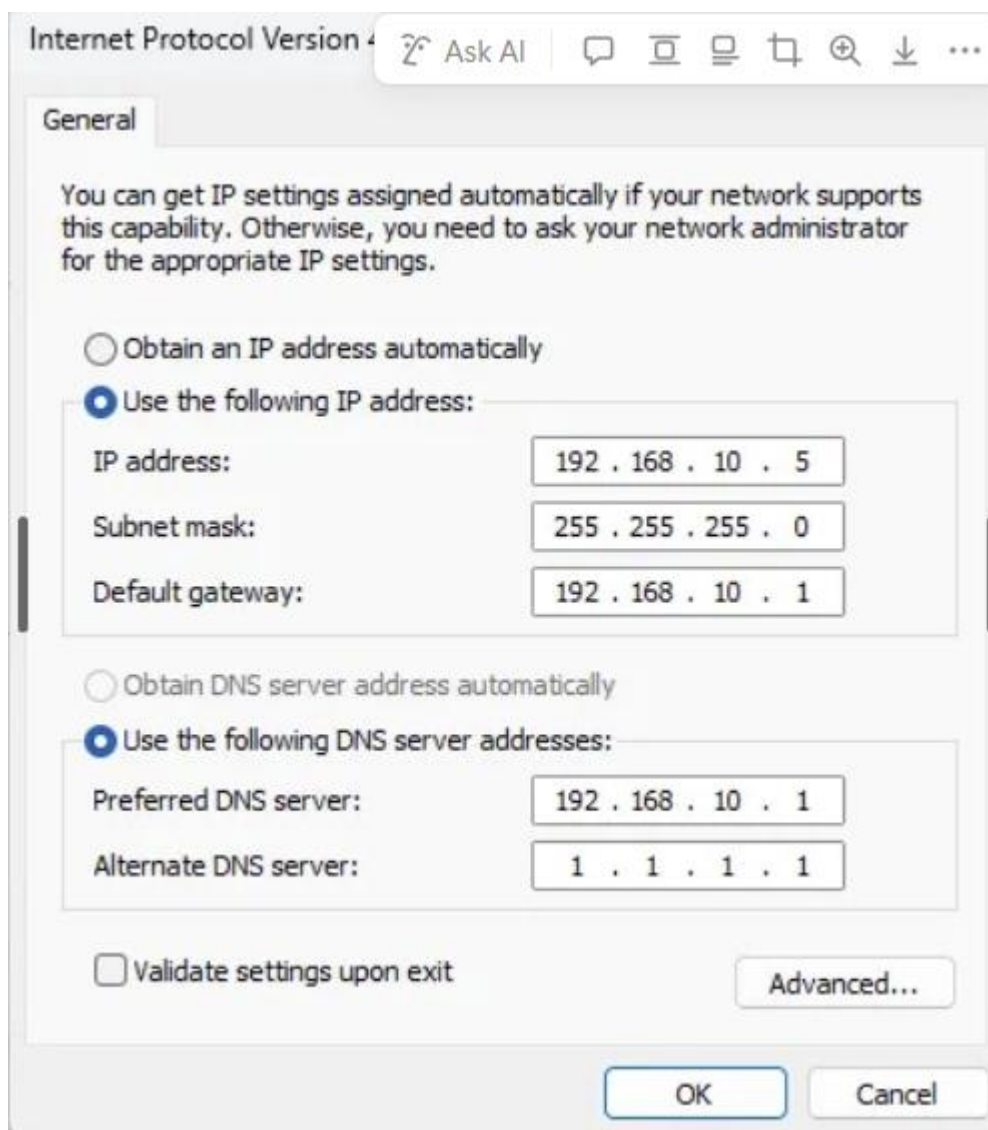
Subnet IP: 192 . 168 . 40 . 0 Subnet mask: 255 . 255 . 255 . 0

LAN40

LAN40 là dành cho quản trị viên và SIEM. Được gán với Host-only và dải IP 192.168.50.0/24



Trong quá trình setup và config, để có thể dễ dàng hơn trong việc cấu hình pfSense, em gán một địa chỉ IP thuộc LAN10 vào máy tính thật để có thể truy cập vào GUI của pfSense thông qua IP 192.168.10.1 (địa chỉ LAN trong pfSense). Sau này khi đã hoàn thành các cấu hình trong pfSense sẽ xóa đi.



3. CÁC CẤU HÌNH CHUNG

Phần này trình bày về các cấu hình bảo mật chung được cài đặt ở trên tất cả các VM (Web Server, Reverse Proxy, File Server, Wazuh).

System Hardening

Chức năng: Cấm hoàn toàn việc đăng nhập trực tiếp từ xa bằng tài khoản root.

Chạy lệnh sau trong Terminal:

```
sudo nano /etc/ssh/sshd_config
```

Và thêm vào các dòng sau:

```
PermitRootLogin no
DebianBanner no
```

Và khởi động lại SSH

```
sudo systemctl restart sshd
```

Cấu hình múi giờ

Chạy lệnh sau trong Terminal

```
sudo timedatectl set-timezone Asia/Ho Chi Minh
```

Cấu hình rootcheck để phát hiện rootkit, trojan, backdoor và các dấu hiệu hệ thống bị xâm phạm.

Thêm các dòng sau vào /var/ossec/etc/ossec.conf

```
<rootcheck>
  <disabled>no</disabled>
  <frequency>43200</frequency>
  <rootkit_files>etc/shared/rootkit_files.txt</rootkit_files>
  <rootkit_trojans>etc/shared/rootkit_trojans.txt</rootkit_trojans>
  <skip_nfs>yes</skip_nfs>
  <ignore>/var/lib/containerd</ignore>
  <ignore>/var/lib/docker/overlay2</ignore>
</rootcheck>
```

Cấu hình FIM

Ở trên các máy có Wazuh Agent, thêm dòng sau vào /var/ossec/etc/ossec.conf

```
<syscheck>
  <disabled>no</disabled>
  <frequency>43200</frequency> <!-- Quét định kỳ 12h/lần để đối chiếu -->
  <scan_on_start>yes</scan_on_start>

  <!-- Cấu hình cảnh báo thời gian thực (Real-time) -->
  <!-- 1. Giám sát thư mục cấu hình hệ thống -->
  <directories check_all="yes" report_changes="yes"
realtime="yes">/etc/ssh</directories>
  <directories check_all="yes" report_changes="yes"
realtime="yes">/etc/pam.d</directories>
```

```

<directories check_all="yes" report_changes="yes"
realtime="yes">/etc/passwd</directories>
<directories check_all="yes" report_changes="yes"
realtime="yes">/etc/shadow</directories>

<!-- 2. Giám sát thư mục Web & Proxy (Dành cho DMZ & Web Server) -->
<directories check_all="yes" report_changes="yes"
realtime="yes">/etc/nginx</directories>
<directories check_all="yes" report_changes="yes"
realtime="yes">/var/www</directories>
<!-- Nếu dùng Docker, giám sát thư mục mount volume của bạn -->
<directories check_all="yes" report_changes="yes"
realtime="yes">/home/h4rrybrwnie/WebGoat</directories>

<!-- 3. Giám sát thư mục chia sẻ (Dành riêng cho File Server) -->
<!-- Chỉ thêm dòng này ở máy File Server LAN 20 -->
<!-- <directories check_all="yes" report_changes="yes"
realtime="yes">/srv/share</directories> -->

<!-- Danh sách loại trừ (Files rác không cần theo dõi) -->
<ignore>/etc/mtab</ignore>
<ignore>/etc/hosts.deny</ignore>
<ignore>/etc/mail/statistics</ignore>
<ignore>/etc/random-seed</ignore>
<ignore>/etc/random.seed</ignore>
<ignore type="sregex">.log$|.swp$</ignore>
</syscheck>

```

Đoạn cấu hình trên kích hoạt module Syscheck của Wazuh để thực hiện giám sát sự thay đổi của các tệp tin quan trọng trên máy chủ theo cơ chế:

Baseline Scanning: Hệ thống tự động quét toàn bộ các thư mục được chỉ định ngay khi khởi động để tạo baseline về trạng thái sạch của hệ thống.

Cơ chế cảnh báo thời gian thực: Kích hoạt tính năng realtime="yes" cho các thư mục trọng yếu. Bất kỳ hành vi thêm/sửa/xóa file nào tại các vùng này sẽ kích hoạt cảnh báo về Wazuh ngay lập tức.

Tối ưu hóa hiệu năng: Thiết lập danh sách loại trừ đối với các file log và các file biên động thường xuyên nhưng không mang rủi ro bảo mật, giúp giảm cảnh báo giả và tiết kiệm tài nguyên hệ thống.

Cấu hình tài khoản IT Support

Trong quá trình cài đặt, nhóm nhận thấy việc sử dụng tài khoản thường h4rrybrwnie có được quyền quản trị (nhóm docker, quyền sudo) có rủi ro về bảo mật lớn. Nếu tài khoản này bị chiếm, Attacker sẽ ngay lập tức có quyền root.

Do đó, nhóm thực hiện tái cấu trúc hệ thống phân quyền với 2 mục tiêu:

- Thu hồi đặc quyền: Ngăn chặn leo thang đặc quyền thông qua Docker Socket.
- Thiết lập tài khoản quản trị định danh: Tạo user chuyên biệt cho việc hỗ trợ kỹ thuật.

Bước 1: Thu hồi quyền docker của người dùng thường

```
h4rrybrwnie@h4rrybrwnie:~$ # Xóa user khỏi nhóm sudo
sudo gpasswd -d h4rrybrwnie sudo
[sudo] password for h4rrybrwnie:
```

Bước 2: Tạo tài khoản quản trị

Thay vì dùng chung tài khoản hoặc dùng trực tiếp root, nhóm tạo ra một tài khoản dành riêng cho IP Support.

```
h4rrybrwnie@h4rrybrwnie:~$ sudo adduser it_support
Adding user `it_support' ...
Adding new group `it_support' (1001) ...
Adding new user `it_support' (1001) with group `it_support' ...
Creating home directory `/home/it_support' ...
Copying files from `/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for it_support
Enter the new value, or press ENTER for the default
    Full Name []: it_support
    Room Number []: 0123456789
    Work Phone []: 0123456789
    Home Phone []:
    Other []:
Is the information correct? [Y/n] Y
```

Bước 3: Cấp quyền quản trị

```
h4rrybrwnie@h4rrybrwnie:~$ groups it_support
it_support : it_support sudo
```


4. PFSENSE

Khi máy thật đã có địa chỉ trong LAN10 (tạm thời), ta vào GUI của pfSense (thông qua IP 192.168.10.1) để hoàn tất thiết lập pfSense, em thiết lập như các ảnh bên dưới:

The image displays two screenshots of the pfSense installation wizard interface.

General Information

On this screen the general pfSense parameters will be set.

Hostname: pfSense-fw
Name of the firewall host, without domain part.
Examples: pfsense, firewall, edgefw

Domain: home.arpa
Domain name for the firewall.
Examples: home.arpa, example.com

Do not end the domain name with '.local' as the final part (Top Level Domain, TLD). The 'local' TLD is widely used by mDNS (e.g. Avahi, Bonjour, Rendezvous, Airprint, Airplay) and some Windows systems and networked devices. These will not network correctly if the router uses 'local' as its TLD. Alternatives such as 'home.arpa', 'local.lan', or 'mylocal' are safe.

The default behavior of the DNS Resolver will ignore manually configured DNS servers for client queries and query root DNS servers directly. To use the manually configured DNS servers below for client queries, visit Services > DNS Resolver and enable DNS Query Forwarding after completing the wizard.

Primary DNS Server: 1.1.1.1

Secondary DNS Server: 8.8.8.8

Override DNS: ☒ Allow DNS servers to be overridden by DHCP/PPP on WAN

RFC1918 Networks

Block RFC1918 Private Networks: ☐ Block private networks from entering via WAN
When set, this option blocks traffic from IP addresses that are reserved for private networks as per RFC 1918 (10/8, 172.16/12, 192.168/16) as well as loopback addresses (127/8). This option should generally be left turned on, unless the WAN network lies in such a private address space, too.

Block bogon networks: ☒ Block non-Internet routed networks from entering via WAN
When set, this option blocks traffic from IP addresses that are reserved (but not RFC 1918) or not yet assigned by IANA. Bogons are prefixes that should never appear in the Internet routing table, and obviously should not appear as the source address in any packets received.

Suricata

Trong pfSense, đã có sẵn packet của Suricata, chỉ cần vào **System** → **Package Manager** → **Available Packages** → Tìm Suricata và Install.

Sau khi Install. Setup Suricata theo các ảnh bên dưới:


System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

Services / Suricata / Global Settings

Interfaces
Global Settings
Updates
Alerts
Blocks
Files
Pass Lists
Suppress
Logs View
Logs Mgmt
SID Mgmt

Sync
IP Lists

Please Choose The Type Of Rules You Wish To Download

Install ETOpen Emerging Threats rules

☒ ETOpen is a free open source set of Suricata rules whose coverage is more limited than ETPro.
☐ Use a custom URL for ETOpen downloads

Enabling the custom URL option will force the use of a custom user-supplied URL when downloading ETOpen rules.

Install ETPro Emerging Threats rules

☐ ETPro for Suricata offers daily updates and extensive coverage of current malware threats.
☐ Use a custom URL for ETPro rule downloads

The ETPro rules contain all of the ETOpen rules, so the ETOpen rules are not required and are disabled when the ETPro rules are selected. Sign Up for an ETPro Account. Enabling the custom URL option will force the use of a custom user-supplied URL when downloading ETPro rules.

Install Snort rules

☐ Snort free Registered User or paid Subscriber rules
☐ Use a custom URL for Snort rule downloads

Sign Up for a free Registered User Rules Account
Sign Up for paid Snort Subscriber Rule Set (by Talos)

Enabling the custom URL option will force the use of a custom user-supplied URL when downloading Snort Subscriber rules.

Install Snort GPLv2 Community rules

☒ The Snort Community Ruleset is a GPLv2 Talos-certified ruleset that is distributed free of charge without any Snort Subscriber License restrictions.
☐ Use a custom URL for Snort GPLv2 rule downloads

This ruleset is updated daily and is a subset of the subscriber ruleset. If you are a Snort Subscriber Rules customer (paid subscriber), the community ruleset is already built into your download of the Snort Subscriber rules, and there is no benefit in adding this rule set separately.

Install Feodo Tracker Botnet C2 IP rules

☒ The Feodo Botnet C2 IP Ruleset contains Dridex and Emotet/Heodo botnet command and control servers (C&Cs) tracked by Feodo Tracker.

Install ABUSE.ch SSL Blacklist rules

☒ The ABUSE.ch SSL Blacklist Ruleset contains the SSL cert fingerprints of all SSL certs blacklisted by ABUSE.ch.

Hide Deprecated Rules Categories

☐ Hide deprecated rules categories in the GUI and remove them from the configuration. Default is Not Checked.

Download Extra Rules

☐ Download Extra Rules

Download extra rules file or tar.gz archive with rules. If "Check MD5" is set, the code will assume a matching filename exists at the same URL with an additional extension of ".md5".

Rules Update Settings

Update Interval

12 HOURS

Please select the interval for rule updates. Choosing NEVER disables auto-updates.

Hint: In most cases, every 12 hours is a good choice.

Update Start Time

00:39

Enter the rule update start time in 24-hour format (HH:MM). Default is 00 hours with a randomly chosen minutes value. Rules will update at the interval

Live Rule Swap on Update	☒ Enable "Live Swap" reload of rules after downloading an update. Default is Not Checked When enabled, Suricata will perform a live load of the new rules following an update instead of a hard restart. If issues are encountered with live load, uncheck this option to perform a hard restart of all Suricata instances following an update.
GeoLite2 DB Update	☒ Enable downloading of free GeoLite2 Country IP Database updates. Default is Not Checked When enabled, Suricata will automatically download updates for the free GeoLite2 country IP database. If you have a subscription for more current GeoIP2 updates, uncheck this option and instead create your own process to place the required database file in /usr/local/share/suricata/GeoLite2/.
GeoLite2 DB Account ID	Enter your MaxMind GeoLite2 Account ID To utilize the free MaxMind GeoLite2 GeoIP functionality, you must register for a free MaxMind user account. Use the GeoIP Update version 3.1.1 or newer registration option.
GeoLite2 DB License Key	Enter your MaxMind GeoLite2 License Key To utilize the free MaxMind GeoLite2 GeoIP functionality, you must register for a free MaxMind user account. Use the GeoIP Update version 3.1.1 or newer registration option.
General Settings	
Remove Blocked Hosts Interval	1 HOUR Please select the amount of time you would like hosts to be blocked. Note this setting is only applicable when using Legacy Mode blocking! This setting is ignored when using Inline IPS Mode. Hint: in most cases, 1 hour is a good choice.
Log to System Log	☒ Copy Suricata messages to the firewall system log.
Log Facility	LOCAL1
Log Facility	LOCAL1 Select system log facility to use for reporting. Default is LOCAL1.
Log Priority	NOTICE Select system log Priority (Level) to use for reporting. Default is NOTICE.
Keep Suricata Settings After Deinstall	☒ Settings will not be removed during package deinstallation.
Clear Blocked Hosts After Deinstall	☒ Click to clear all blocked hosts added by Suricata when removing the package. Default is checked.
Notifications	

Rules

WAN

Trên WAN Interface, nhóm đã áp dụng chính sách “Default Deny” và chỉ mở các port cần thiết nhất

1. Block Bogon Network: Chặn các lưu lượng đến từ các địa chỉ IP “Bogon” để chống lại các cuộc tấn công giả mạo địa chỉ nguồn và giảm nhiễu từ các gói tin rác trên Internet.
2. Anti-Recon: Block Ping to WAN: Chặn toàn bộ các gói tin ICMP (Ping) gửi đến địa chỉ WAN của Firewall để ngăn chặn bước thu thập thông tin ban đầu của Attacker.
3. NAT Access HTTP/HTTPS: Hệ thống chỉ chấp nhận các kết nối TCP nhắm vào cổng Web, lưu lượng sau khi qua cổng này sẽ được NAT và chuyển tiếp vào máy chủ Reverse Proxy / WAF. Đảm bảo chỉ mở đúng 2 cổng cần thiết, đóng tất cả các cổng quản trị khác (như SSH port 22, Database port 3306, ...).

4. WAN Default Deny: Chặn tất cả lưu lượng còn lại không khớp với các luật bên trên. Mục đích là để thực thi mô hình Zero Trust, ngăn chặn mọi nỗ lực kết nối trái phép vào các dịch vụ không công khai.

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	✗	0/0 B	*	Reserved Not assigned by IANA	*	*	*	*	*	Block bogon networks	
☐	✗	IPv4 ICMP	*	*	WAN address	*	*	none		Anti-Recon: Block Ping to WAN	
☐	✓	IPv4 TCP	*	*	Host_Proxy	80 (HTTP)	*	none		NAT Access HTTP	
☐	✓	IPv4 TCP	*	*	Host_Proxy	443 (HTTPS)	*	none		NAT Access HTTPS	
☐	✗	IPv4 *	*	*	*	*	*	none		WAN Default Deny	

Add
 Add
 Delete
 Toggle
 Copy
 Save
 Separator

LAN10

Trên LAN (LAN10) Interface, nơi đặt Web Server, nhóm đã áp dụng chính sách thắt chặt để đảm bảo Web Server chỉ làm đúng chức năng của nó và không thể bị lợi dụng để tấn công sang các vùng mạng khác.

1. Anti-Lockout Rule: Đảm bảo quản trị viên không vô tình tự khóa mình khỏi giao diện quản trị Web/SSH của Firewall nếu lỡ tay cấu hình sai các luật.
2. Log to Wazuh: Cho phép Wazuh Agent cài trên Web Server gửi log về máy chủ trung tâm để phân tích.
3. DNS: Cho phép Web Server phân giải tên miền để thực hiện các kết nối ra ngoài hoặc cập nhật phần mềm.
4. Web Update HTTP/HTTPS: Luật này cho phép Web Server đi ra Internet.
5. LAN10: ISOLATION: Chống Lateral Movement, nếu Web Server bị Attacker chiếm quyền điều khiển sẽ không thể di chuyển sang các mạng khác.

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	5/100 KiB	*	*	*	LAN Address	80 22	*	*		Anti-Lockout Rule	
☐		IPv4 TCP	Host_Web	*	Host_File_DB	Ports_Data_Svc	*	none		LAN10: Web -> Backend Data	
☐		IPv4 TCP	Host_Web	*	Host_Wazuh	Ports_Wazuh_Agent	*	none		LAN10: Log to Wazuh	
☐		IPv4 UDP	LAN subnets	*	192.168.10.1	53 (DNS)	*	none		LAN10: DNS	
☐		IPv4 TCP	Host_Web	*	! RFC1918_Networks	80 (HTTP)	*	none		LAN10: Web Update HTTP	
☐		IPv4 TCP	Host_Web	*	! RFC1918_Networks	443 (HTTPS)	*	none		LAN10: Web Update HTTPS	
☐		IPv4 *	LAN subnets	*	RFC1918_Networks	*	*	none		LAN10: ISOLATION	

Add
 Add
 Delete
 Toggle
 Copy
 Save
 Separator

DMZ

Các luật Firewall tại đây tuân thủ nghiêm ngặt các quy tắc chỉ cho phép Forwarding và chặn mọi kết nối vào trong.

1. Proxy -> Web Server: Đảm bảo Web Server trong LAN10 không phải tiếp xúc trực tiếp với Internet.
2. Log to Wazuh: Cho phép Reverse Proxy gửi log về cho Wazuh phân tích.
3. DNS: Để máy Proxy có thể phân giải tên miền (phục vụ việc update hoặc forward domain).
- 4 & 5: Proxy Update HTTP/HTTPS: Chỉ cho phép ra Internet, cấm vào mạng nội bộ.
6. DMZ Isolation: Ngăn chặn Pivot Prevention.

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐		IPv4 TCP	Host_Proxy	*	Host_Web	Ports_Web_Svc	*	none		DMZ: Proxy -> Web Server	
☐		IPv4 TCP	DMZ subnets	*	Host_Wazuh	Ports_Wazuh_Agent	*	none		DMZ: Log to Wazuh	
☐		IPv4 UDP	DMZ subnets	*	192.168.20.1	53 (DNS)	*	none		DMZ: DNS	
☐		IPv4 TCP	Host_Proxy	*	! RFC1918_Networks	80 (HTTP)	*	none		DMZ: Proxy Update HTTP	
☐		IPv4 TCP	Host_Proxy	*	! RFC1918_Networks	443 (HTTPS)	*	none		DMZ: Proxy Update HTTPS	
☐		IPv4 *	DMZ subnets	*	RFC1918_Networks	*	*	none		DMZ: ISOLATION (Block to Internal)	

Add
 Add
 Delete
 Toggle
 Copy
 Save
 Separator

LAN20

Vùng LAN20 là nơi lưu trữ dữ liệu. Chính sách tại đây tuân thủ theo các quy tắc sau :

1. Log to Wazuh : Đảm bảo mọi hoạt động truy xuất dữ liệu, đăng nhập hay thay đổi file trên máy chủ Database đều được ghi lại và gửi về SIEM để giám sát.
2. DNS : Cho phép máy chủ phân giải tên miền phục vụ cho việc cập nhật hệ thống.
- 3 & 4. AV Update HTTP/HTTPS : Cho phép File Server cập nhật, giảm thiểu rủi ro bị Attacker lợi dụng để tấn công các vùng khác.
5. LAN20: ISOLATION: Đây là luật chống Lateral Movement.

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	IPv4 TCP	Host_File_DB	*	Host_Wazuh	Ports_Wazuh_Agent	*	none		LAN20: Log to Wazuh	
☐	✓	IPv4 UDP	LAN20 subnets	*	192.168.30.1	53 (DNS)	*	none		LAN20: DNS	
☐	✓	IPv4 TCP	Host_File_DB	*	! RFC1918_Networks	80 (HTTP)	*	none		LAN20: AV Update HTTP	
☐	✓	IPv4 TCP	Host_File_DB	*	! RFC1918_Networks	443 (HTTPS)	*	none		LAN20: AV Update HTTPS	
☐	✗	IPv4 *	LAN20 subnets	*	RFC1918_Networks	*	*	none		LAN20: ISOLATION	

Add
 Add
 Delete
 Toggle
 Copy
 Save
 Separator

LAN30

Vùng LAN30 chứa các máy của nhân viên.

1. Block Firewall Login: Ngăn chặn nhân viên hoặc Attacker cố gắng truy cập vào trang quản trị của pfSense.
2. Access File Share: Cho phép nhân viên truy cập File Server để lấy tài liệu.
3. Log to Wazuh: Để Wazuh Agent trên máy nhân viên gửi log về Server, giúp phát hiện sớm mã độc.
4. DNS: Phân giải tên miền để truy cập Internet.
5. Allow Internet: Nhân viên được phép lướt web, check mail, ...
6. LAN30: ISOLATION: Tránh các cuộc tấn công Lateral Movement.

Floating

WAN

LAN

DMZ

LAN20

LAN30

LAN40

Rules (Drag to Change Order)

States

Protocol

Source

Port

Destination

Port

Gateway

Queue

Schedule

Description

Actions

✖

☰

IPv4 TCP

LAN30 subnets

*

192.168.40.1

Ports_Mgmt

*

none

LAN30: Block Firewall Login

✓

IPv4 TCP

LAN30 subnets

*

Host_File_DB

Ports_Data_Svc

*

none

LAN30: Access File Share

✓

IPv4 TCP

LAN30 subnets

*

Host_Wazuh

Ports_Wazuh_Agent

*

none

LAN30: Log to Wazuh

✓

IPv4 UDP

LAN30 subnets

*

192.168.40.1

53 (DNS)

*

none

LAN30: DNS

✓

IPv4 *

LAN30 subnets

*

! RFC1918_Networks

*

*

none

LAN30: Allow Internet

✖

☰

IPv4 *

LAN30 subnets

*

RFC1918_Networks

*

*

none

LAN30: ISOLATION

Add

Add

Delete

Toggle

Copy

Save

Separator

LAN40

Vùng LAN40 đóng vai trò SOC và quản trị hệ thống.

1. Admin Login to Firewall: Cho phép quản trị viên đăng nhập vào giao diện Web/SSH của pfSense để cấu hình hệ thống.
2. Admin SSH/RDP to All Servers: Đây là luật cho quản trị viên có thể truy cập vào hệ thống để bảo trì.
3. Wazuh Update Threat Intel: Biến máy này thành một PAW (Privileged Access Workstation) an toàn. Vì admin không thể lướt Web, check mail cá nhân trên máy này, nguy cơ bị dính mã độc từ Internet giảm xuống gần bằng 0.
4. Default Deny: Đảm bảo không có luồng nào khác được phép diễn ra ngoài các mục quản trị viên đã định nghĩa.

Floating

WAN

LAN

DMZ

LAN20

LAN30

LAN40

Rules (Drag to Change Order)

States

Protocol

Source

Port

Destination

Port

Gateway

Queue

Schedule

Description

Actions

✓

☰

IPv4 TCP

LAN40 subnets

*

192.168.50.1

Ports_Mgmt

*

none

LAN40: Admin Login Firewall

✓

☰

IPv4 TCP

LAN40 subnets

*

RFC1918_Networks

Ports_Mgmt

*

none

LAN40: Admin SSH/RDP to All Servers

✓

☑

IPv4 TCP

Host_Wazuh

*

! RFC1918_Networks

443 (HTTPS)

*

none

LAN40: Wazuh Update Threat Intel

✗

☰

IPv4 *

*

*

*

*

*

none

LAN40: Default Deny

Add

Add

Delete

Toggle

Copy

Save

Separator

Aliases

Firewall Aliases IP				
Name	Type	Values	Description	Actions
Host_File_DB	Host(s)	192.168.30.10	File Server & Data Backend (LAN20)	  
Host_Proxy	Host(s)	192.168.20.10	Nginx Reverse Proxy (DMZ)	  
Host_Wazuh	Host(s)	192.168.50.10	Wazuh SIEM Server (LAN40)	  
Host_Web	Host(s)	192.168.10.10	Web Server Production (LAN10)	  
RFC1918_Networks	Network(s)	192.168.0.0/16, 10.0.0.0/8, 172.16.0.0/12	Private Networks (Block internal traffic)	  

Để tăng cường khả năng quản lý và sự dễ đọc của các luật Firewall, nhóm đã định nghĩa các Aliases đại diện cho các máy chủ và vùng mạng quan trọng.

Hosts

Host_Web (192.168.10.10): Máy chủ Web (Backend) nằm trong vùng LAN10, chỉ nhận kết nối từ Proxy (DMZ) và kết nối đến File Server (LAN20).

Host_Proxy (192.168.20.10) : Máy chủ Reverse Proxy (Nginx +ModSecurity) nằm trong vùng DMZ.

Host_File_DB (192.168.30.10): Máy chủ dữ liệu & lưu trữ nằm trong vùng LAN20.

Host_Wazuh (192.168.50.10): Máy chủ SIEM Wazuh nằm trong vùng quản trị LAN40.

Alias đại diện cho Networks

RFC1918_Networks (192.168.0.0/16, 10.0.0.0/8, 172.16.0.0/12): Đây là 3 dải địa chỉ IP Private được quy định bởi tổ chức IETF trong tài liệu RFC1918.

5. DMZ (REVERSE PROXY + WAF)

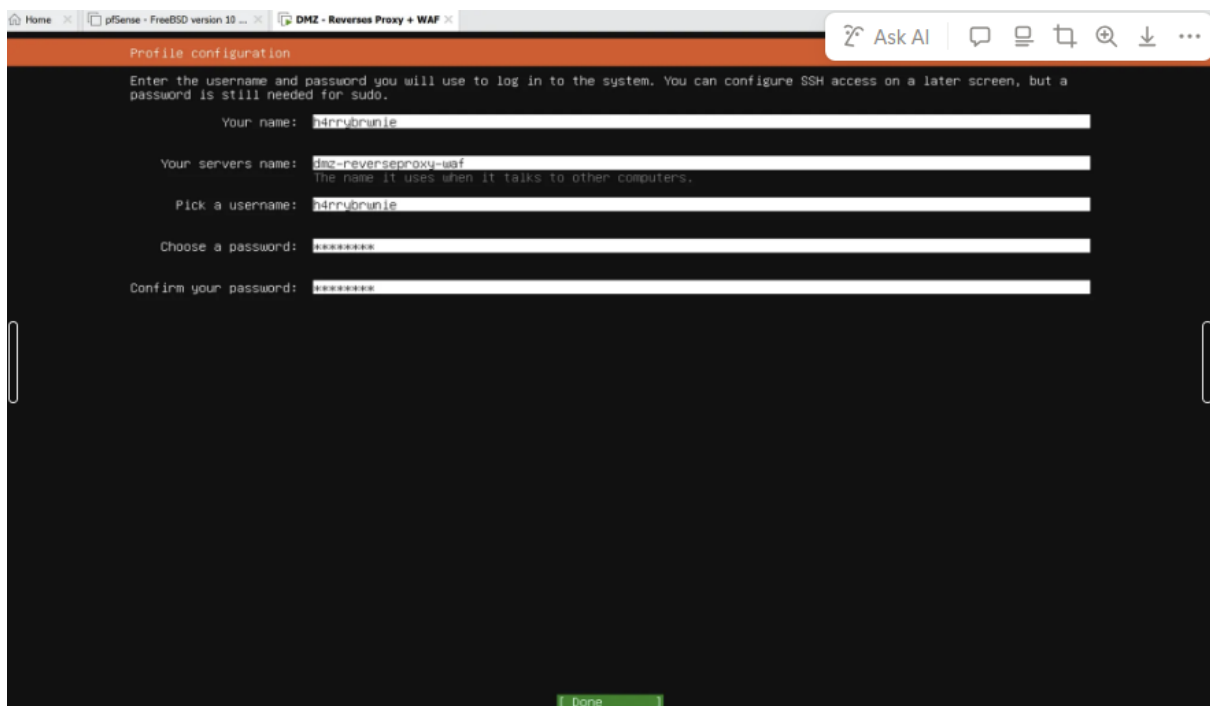
Mục tiêu

Xây dựng một vùng mạng trung gian đóng vai trò như lớp phòng thủ đầu tiên cho hệ thống Web, với các nhiệm vụ cụ thể như:

- Thiết lập cơ chế Reverse Proxy
- Triển khai WAF
- System Hardening
- Đảm bảo tính sẵn sàng và kiểm soát

Tạo và config DMZ

Sử dụng phần mềm VMWare Workstation để tạo các máy ảo phục vụ cho đồ án. Đầu tiên ta tạo máy ảo trung vùng mạng DMZ (192.168.20.0/24). Sử dụng Ubuntu 22-04 LTS. Thiết lập tên và tên server như sau:



Sau khi tạo máy ảo thành công, ta cần phải gán địa chỉ IP tĩnh cho máy này theo các bước như sau:

Chỉnh sửa file cấu hình mạng

```
sudo nano /etc/netplan/01-netcfg.yaml
```

Nội dung trong file 01-netcfg.yaml

```
network:
  version: 2
  renderer: networkd
  ethernets:
    ens33:
      addresses: [192.168.20.10/24]
      gateway4: 192.168.20.1
      nameservers:
        addresses: [1.1.1.1, 8.8.8.8]
```

Cấp quyền cho file config

```
sudo chmod 600 /etc/netplan/01-netcfg.yaml
```

Áp dụng địa chỉ vừa config

```
sudo netplan apply
```

Các câu lệnh kiểm tra


```
ip a
ping 192.168.10.1
```

```
h4rrybrwnie@dmz-reverseproxy-waf:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:0b:2f:3f brd ff:ff:ff:ff:ff:ff
    altname enp2s1
    inet 192.168.20.10/24 brd 192.168.20.255 scope global ens33
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe0b:2f3f/64 scope link
        valid_lft forever preferred_lft forever
h4rrybrwnie@dmz-reverseproxy-waf:~$ ping 192.168.10.1
PING 192.168.10.1 (192.168.10.1) 56(84) bytes of data.
64 bytes from 192.168.10.1: icmp_seq=1 ttl=64 time=0.256 ms
64 bytes from 192.168.10.1: icmp_seq=2 ttl=64 time=0.797 ms
64 bytes from 192.168.10.1: icmp_seq=3 ttl=64 time=0.331 ms
^C
--- 192.168.10.1 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2023ms
rtt min/avg/max/mdev = 0.256/0.461/0.797/0.239 ms
```

Kiểm tra lại trong Terminal máy DMZ đã nhận được IP 192.168.20.10, và ping thử 192.168.10.1 (LAN10), chứng tỏ pfSense đã thành công thực hiện nhiệm vụ Routing.

Cài Nginx Reverse Proxy trong DMZ

Bước 1: Cập nhật hệ thống

```
sudo apt update && sudo apt upgrade -y
```

Bước 2: Cài và khởi động Nginx

```
sudo apt install nginx -y
sudo systemctl enable nginx
sudo systemctl start nginx
```

Bước 3: Kiểm tra xem Nginx đã hoạt động chưa?

```
sudo systemctl status nginx
```

```
h4rrybrwnie@dmz-reverseproxy-waf:~$ sudo systemctl status nginx
[sudo] password for h4rrybrwnie:
• nginx.service - A high performance web server and a reverse proxy server
   Loaded: loaded (/usr/lib/systemd/system/nginx.service; enabled; preset: enabled)
   Active: active (running) since Thu 2025-12-04 06:47:39 UTC; 11min ago
     Docs: man:nginx(8)
   Process: 1232 ExecStartPre=/usr/sbin/nginx -t -q -g daemon on; master_process on; (code=exited, status=0/SUCCESS)
   Process: 1237 ExecStart=/usr/sbin/nginx -g daemon on; master_process on; (code=exited, status=0/SUCCESS)
  Main PID: 1238 (nginx)
    Tasks: 3 (limit: 4545)
   Memory: 3.7M (peak: 4.0M)
      CPU: 17ms
   CGroup: /system.slice/nginx.service
           └─1238 "nginx: master process /usr/sbin/nginx -g daemon on; master_process on;"
             └─1240 "nginx: worker process"
               └─1241 "nginx: worker process"

Dec 04 06:47:39 dmz-reverseproxy-waf systemd[1]: Starting nginx.service - A high performance web server and a reverse proxy server...
Dec 04 06:47:39 dmz-reverseproxy-waf systemd[1]: Started nginx.service - A high performance web server and a reverse proxy server.
h4rrybrwnie@dmz-reverseproxy-waf:~$ _
```

Từ màn hình Terminal, ta thấy dòng “Active: active (running)” → Nginx đang hoạt động tốt

Cấu hình Reverse Proxy

Bước 1: Xóa cấu hình mặc định

```
sudo rm /etc/nginx/sites-enabled/default
```

Bước 2: Tạo site mới

```
sudo nano /etc/nginx/sites-available/reverse-proxy
```

Bước 3: Kích hoạt

```
Sudo ln -s /etc/nginx/sites-available/reverse-proxy /etc/nginx/sites-enabled/  
sudo nginx -t  
sudo systemctl reload nginx
```

Ấn thông tin máy chủ

Chỉnh sửa file cấu hình /etc/nginx/nginx.conf

```
sudo nano /etc/nginx/nginx.conf
```

thêm `server_tokens off;` vào trong khối `http{...}`

Kích hoạt ModSecurity WAF

Bật module ModSecurity và nạp bộ luật bảo vệ (thường là OWASP Core Rule Set – CRS).

Tác dụng: Biến Nginx từ một Proxy thông thường thành một WAF, có khả năng phân tích và chặn các tấn công như SQLi, XSS.

```
modsecurity on;  
modsecurity_rules_file /etc/nginx/modsec/main.conf;
```

Chặn các đường dẫn nhạy cảm

Câu lệnh:

```
location ~* /actuator { deny all; return 404; }  
location ~* /(heapdump|loggers|auditevents|env|configprops) { ... }
```

Cấu hình Proxy và tính chỉnh luật

Chuyển tiếp (Proxy Pass): Chuyển tiếp request sạch vào Web Server thật sự nằm ở LAN10.

```
proxy_pass http://192.168.10.10:8888/;
```

Giữ nguyên IP gốc: giúp Web Server bên trong nhìn thấy IP thật của Attacker thay vì IP của máy Proxy. Nếu thiếu dòng này, logs bên trong sẽ sai lệch.

```
proxy_set_header X-Real-IP $remote_addr;
```

Xử lý báo động giả

```
SecRuleRemoveById 920350
```

Sau khi thực hiện các cấu hình trên:

```
sudo systemctl reload nginx
```

6. LAN10 (WEB SERVER)

Mục tiêu

Máy WebServer (192.168.10.10) trong mạng LAN10 sẽ:

- Chạy nginx.
- Lắng nghe trên port 8080.
- Có trang web test (“Backend WebServer – 192.168.10.10:8080”).
- Cho phép Reverse Proxy (192.168.20.10) truy cập.

Tạo và config LAN10

```
# Chỉnh sửa file cấu hình mạng  
sudo nano /etc/netplan/01-netcfg.yaml
```

```
# Nội dung trong file 01-netcfg.yaml  
network:  
  version: 2  
  renderer: networkd  
  ethernets:  
    ens33:  
      addresses: [192.168.10.10/24]  
      gateway4: 192.168.10.1  
      nameservers:  
        addresses: [1.1.1.1, 8.8.8.8]
```

```
# Cấp quyền cho file config  
sudo chmod 600 /etc/netplan/01-netcfg.yaml
```

```
# Áp dụng địa chỉ IP vừa config
sudo netplan apply
```

Cài đặt Nginx

Bước 1: Cập nhật hệ thống và tải Nginx

```
sudo apt update
sudo apt install -y nginx
```

Bước 2: Kiểm tra và bật Nginx

```
sudo systemctl enable --now nginx
sudo systemctl status nginx
```

```
lan10-webserver:~$ sudo systemctl status nginx
[sudo] password for h4rrybrwnie:
● nginx.service - A high performance web server and a reverse proxy server
   Loaded: loaded (/usr/lib/systemd/system/nginx.service; enabled; preset: enabled)
   Active: active (running) since Thu 2025-12-04 07:15:30 UTC; 31s ago
     Docs: man:nginx(8)
   Process: 1270 ExecStartPre=/usr/sbin/nginx -t -q -g daemon on; master_process on; (code=exited, status=0/SUCCESS)
   Process: 1273 ExecStart=/usr/sbin/nginx -g daemon on; master_process on; (code=exited, status=0/SUCCESS)
   Main PID: 1282 (nginx)
    Tasks: 3 (limit: 4545)
   Memory: 3.7M (peak: 3.9M)
      CPU: 16ms
   CGroup: /system.slice/nginx.service
           └─1282 "nginx: master process /usr/sbin/nginx -g daemon on; master_process on;"
             └─1285 "nginx: worker process"
               └─1286 "nginx: worker process"

Dec 04 07:15:30 lan10-webserver systemd[1]: Starting nginx.service - A high performance web server and a reverse proxy server...
Dec 04 07:15:30 lan10-webserver systemd[1]: Started nginx.service - A high performance web server and a reverse proxy server.
```

Gỡ user khỏi nhóm Docker:

Để ngăn chặn user h4rrybrwnie (hoặc user bị hack) tự ý chạy lệnh docker run để tạo container độc hại.

```
sudo gpasswd -d h4rrybrwnie docker
sudo nano /etc/docker/daemon.json
```

Đóng gói Image ra file (Backup)

```
sudo docker save -o webgoat_offline.tar webgoat/webgoat
```

Bật userns-remap để ánh xạ (remap) UID/GID root của container sang một UID/GID không đặc quyền trên máy host

Sửa file /etc/docker/daemon.json

```
sudo nano /etc/docker/daemon.json
```

Thêm nội dung:

```
{  
  "users-remap": "default"  
}
```

Khởi động lại Docker:

```
sudo systemctl restart docker
```

7. LAN20 (FILE SERVER)

Tạo và config LAN20

```
sudo nano /etc/netplan/01-netcfg.yaml  
network:  
  version: 2  
  renderer: networkd  
  ethernets:  
    ens33:  
      addresses: [192.168.30.10/24]  
      gateway4: 192.168.30.1  
      nameservers:  
        addresses: [8.8.8.8, 1.1.1.1]
```

Cài và cấu hình Samba

Bước 1: Cài đặt Samba

```
sudo apt update  
sudo apt install samba -y
```

Bước 2: Tạo thư mục chia sẻ

```
sudo mkdir -p /srv/share  
sudo chmod 770 /srv/share
```

Bước 3: Thêm cấu hình chia sẻ vào cuối file /etc/samba/smb.conf:

```
sudo nano /etc/samba/smb.conf
```

Thêm đoạn:

```
[share]  
  path = /srv/share  
  browseable = yes  
  read only = no  
  guest ok = yes
```

Bước 4: Restart Samba:

```
sudo systemctl restart smbd  
sudo systemctl enable smbd
```

Bước 5: Kiểm tra Samba đang hoạt động

Kiểm tra port SMB (445):

```
sudo ss -tlnl | grep 445  
h4rrybrwnie@lan20-fileserver:~$ sudo ss -tlnl | grep 445  
[sudo] password for h4rrybrwnie:  
tcp    LISTEN 0      50      0.0.0.0:445      0.0.0.0:*  
tcp    LISTEN 0      50      [::]:445        [::]:*  
h4rrybrwnie@lan20-fileserver:~$ _
```

Cài đặt ClamAV

```
sudo apt update  
sudo apt install clamav clamav-daemon -y  
sudo systemctl stop clamav-freshclam  
sudo freshclam  
sudo systemctl start clamav-freshclam  
sudo systemctl enable clamav-freshclam
```

Chuẩn bị thư mục Log cho ClamAV

```
sudo mkdir -p /var/log/clamav  
sudo chown clamav:clamav /var/log/clamav
```

Cấu hình Lịch trình

Mở trình chỉnh sửa Cron:

```
sudo crontab -e
```

Dán nội dung sau vào cuối file:

```
0 2 * * * /usr/bin/clamscan -r /srv/share --log=/var/log/clamav/daily_scan.log
```

Kiểm tra hoạt động của clamav và log:

```
h4rrybrwnie@lan20-fileserver:/var/backups/daily$ systemctl status clamav-daemon
● clamav-daemon.service - Clam AntiVirus userspace daemon
   Loaded: loaded (/usr/lib/systemd/system/clamav-daemon.service; enabled; preset: enabled)
   Drop-In: /etc/systemd/system/clamav-daemon.service.d
            └─extend.conf
   Active: active (running) since Fri Dec 2025-12-12 09:53:59 +07; 45min ago
   TriggeredBy: ● clamav-daemon.socket
     Docs: man:clamd(8)
           man:clamd.conf(5)
           https://docs.clamav.net/
   Main PID: 899 (clamd)
     Tasks: 2 (limit: 4548)
    Memory: 1.5G (peak: 1.5G)
       CPU: 30.441s
    CGroup: /system.slice/clamav-daemon.service
            └─899 /usr/sbin/clamd --foreground=true

Dec 12 09:54:31 lan20-fileserver clamd[899]: Fri Dec 12 09:54:31 2025 -> ELF support enabled.
Dec 12 09:54:31 lan20-fileserver clamd[899]: Fri Dec 12 09:54:31 2025 -> Mail files support enabled.
Dec 12 09:54:31 lan20-fileserver clamd[899]: Fri Dec 12 09:54:31 2025 -> OLE2 support enabled.
Dec 12 09:54:31 lan20-fileserver clamd[899]: Fri Dec 12 09:54:31 2025 -> PDF support enabled.
Dec 12 09:54:31 lan20-fileserver clamd[899]: Fri Dec 12 09:54:31 2025 -> SWF support enabled.
Dec 12 09:54:31 lan20-fileserver clamd[899]: Fri Dec 12 09:54:31 2025 -> HTML support enabled.
Dec 12 09:54:31 lan20-fileserver clamd[899]: Fri Dec 12 09:54:31 2025 -> XMLDOCS support enabled.
Dec 12 09:54:31 lan20-fileserver clamd[899]: Fri Dec 12 09:54:31 2025 -> HWP3 support enabled.
Dec 12 09:54:31 lan20-fileserver clamd[899]: Fri Dec 12 09:54:31 2025 -> OneNote support enabled.
Dec 12 09:54:31 lan20-fileserver clamd[899]: Fri Dec 12 09:54:31 2025 -> Self checking every 3600 seconds.
```

```
h4rrybrwnie@lan20-fileserver:/var/log/clamav$ sudo cat clamav.log
Sun Dec 7 01:00:02 2025 -> SelfCheck: Database status OK.
Sun Dec 7 02:00:02 2025 -> SelfCheck: Database status OK.
Mon Dec 8 10:12:47 2025 -> +++ Started at Mon Dec 8 10:12:47 2025
Mon Dec 8 10:12:47 2025 -> Received 1 file descriptor(s) from systemd.
Mon Dec 8 10:12:47 2025 -> clamd daemon 1.4.3 (OS: Linux, ARCH: x86_64, CPU: x86_64)
Mon Dec 8 10:12:47 2025 -> Log file size limited to 9223372036854775807 bytes.
Mon Dec 8 10:12:47 2025 -> Reading databases from /var/lib/clamav
Mon Dec 8 10:12:47 2025 -> Not loading PUA signatures.
Mon Dec 8 10:12:47 2025 -> Bytecode: Security mode set to "TrustSigned".
Mon Dec 8 10:13:08 2025 -> Loaded 8708970 signatures.
Mon Dec 8 10:13:11 2025 -> TCP: No tcp AF_INET/AF_INET6 SOCK_STREAM socket received from systemd.
Mon Dec 8 10:13:11 2025 -> LOCAL: Received AF_UNIX SOCK_STREAM socket from systemd.
Mon Dec 8 10:13:11 2025 -> Limits: Global time limit set to 120000 milliseconds.
Mon Dec 8 10:13:11 2025 -> Limits: Global size limit set to 104857600 bytes.
Mon Dec 8 10:13:11 2025 -> Limits: File size limit set to 26214400 bytes.
Mon Dec 8 10:13:11 2025 -> Limits: Recursion level limit set to 16.
```

Cấu hình Backup tự động

```
sudo mkdir -p /backup
sudo chmod 700 /backup
```

Tạo Script Backup:

```
sudo nano /usr/local/bin/daily_backup.sh
```

Thêm khối lệnh sau:

```
#!/bin/bash

# --- 1. CẤU HÌNH ---
SOURCE="/srv/share"
```

```

DEST="/var/backups/daily"
DATE=$(date +%Y-%m-%d)
FILE="backup-$DATE.tar.gz"
LOG_FILE="/var/log/backup.log" # Thêm file log riêng để debug

# Tạo thư mục đích nếu chưa có
mkdir -p $DEST

# --- 2. THỰC HIỆN BACKUP ---
echo "[$DATE $(date +%T)] Bắt đầu backup..." >> $LOG_FILE

# Nén dữ liệu (Thêm 2>> để ghi lỗi vào log nếu có)
tar -czf $DEST/$FILE $SOURCE 2>> $LOG_FILE

# --- 3. KIỂM TRA & BÁO CÁO (QUAN TRỌNG CHO WAZUH) ---
if [ $? -eq 0 ]; then
    # Nếu thành công (Exit code = 0)
    echo "[$DATE $(date +%T)] Backup THÀNH CÔNG: $FILE" >> $LOG_FILE
    # Gửi tín hiệu cho Syslog (để Wazuh bắt được)
    logger "Backup Job: SUCCESS - File saved to $DEST/$FILE"
else
    # Nếu thất bại
    echo "[$DATE $(date +%T)] Backup THẤT BẠI!" >> $LOG_FILE
    logger "Backup Job: FAILED - Check $LOG_FILE"
    exit 1
fi

# --- 4. DỌN DỆP (RETENTION POLICY) ---
# Sửa +1 thành +7 để giữ lại 1 tuần (An toàn hơn)
find $DEST -type f -name "*.tar.gz" -mtime +7 -delete

```

Cấp quyền thực thi cho Script

```
sudo chmod +x /usr/local/bin/daily_backup.sh
```

Thêm vào lịch trình:

```
sudo crontab -e
```

Thêm dòng sau xuống cuối file:

```
0 23 * * * /usr/local/bin/daily_backup.sh
```


Kiểm tra backup:

```
h4rrybrwnie@lan20-fileserver:/var/backups/daily$ ls -l /usr/local/bin/daily_backup.sh
cat /usr/local/bin/daily_backup.sh
-rwxr-xr-x 1 root root 1110 Dec 12 10:28 /usr/local/bin/daily_backup.sh
#!/bin/bash

# --- 1. CẤU HÌNH ---
SOURCE="/srv/share"
DEST="/var/backups/daily"
DATE=$(date +%Y-%m-%d)
FILE="backup-$DATE.tar.gz"
LOG_FILE="/var/log/backup.log" # Thêm file log riêng để debug

# Tạo thư mục đích nếu chưa có
mkdir -p $DEST

# --- 2. THỰC HIỆN BACKUP ---
echo "[$DATE $(date +%T)] Bắt đầu backup..." >> $LOG_FILE

# Nén dữ liệu (Thêm 2>> để ghi lỗi vào log nếu có)
tar -czf $DEST/$FILE $SOURCE 2>> $LOG_FILE

# --- 3. KIỂM TRA & BÁO CÁO (QUAN TRỌNG CHO WAZUH) ---
if [ $? -eq 0 ]; then
    # Nếu thành công (Exit code = 0)
    echo "[$DATE $(date +%T)] Backup THÀNH CÔNG: $FILE" >> $LOG_FILE
    # Gửi tín hiệu cho Syslog (để Wazuh bắt được)
    logger "Backup Job: SUCCESS - File saved to $DEST/$FILE"
else
    # Nếu thất bại
    echo "[$DATE $(date +%T)] Backup THẤT BẠI!" >> $LOG_FILE
fi

h4rrybrwnie@lan20-fileserver:/var/backups/daily$ ls -lh /var/backups/daily
total 4.0K
-rw-r--r-- 1 root root 115 Dec  6 23:00 backup-2025-12-06.tar.gz
```

```

h4rrybrwnie@lan20-fileserver:/var/backups/daily$ sudo crontab -l
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow  command
0 23 * * * /usr/local/bin/daily_backup.sh
0 2 * * * /usr/bin/clamscan -r /srv/share --log=/var/log/clamav/daily_scan.log
h4rrybrwnie@lan20-fileserver:/var/backups/daily$

```

Tạo Tài khoản người dùng

Tạo user hệ thống Linux:

```
sudo adduser nhanvien
```

```

h4rrybrwnie@lan20-fileserver:~$ sudo adduser nhanvien
[sudo] password for h4rrybrwnie:
info: Adding user `nhanvien' ...
info: Selecting UID/GID from range 1000 to 59999 ...
info: Adding new group `nhanvien' (1001) ...
info: Adding new user `nhanvien' (1001) with group `nhanvien (1001)' ...
info: Creating home directory `/home/nhanvien' ...
info: Copying files from `/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for nhanvien
Enter the new value, or press ENTER for the default
    Full Name []: employee
    Room Number []: 1
    Work Phone []: 0123456789
    Home Phone []: 0123456789
    Other []:
Is the information correct? [Y/n] Y
info: Adding new user `nhanvien' to supplemental / extra groups `users' ...

```

Cấu hình Samba

```
sudo smbpasswd -a nhanvien
```

```
h4rrybrwnie@lan20-fileserver:~$ sudo smbpasswd -a nhanvien
New SMB password:
Retype new SMB password:
Added user nhanvien.
```

Kích hoạt user Samba:

```
sudo smbpasswd -e nhanvien
```

Phân quyền thư mục:

Chuyển quyền sở hữu thư mục share cho user mới:

```
sudo chown -R nhanvien:nhanvien /srv/share
```

Thiết lập quyền hạn chặt chẽ:

```
sudo chmod 770 /srv/share
```

Tắt tính năng Guest và ép buộc xác thực

```
sudo nano /etc/samba/smb.conf
```

Tìm và vô hiệu hóa Guest Mapping để ngăn chặn việc "Đăng nhập sai nhưng vẫn được vào":

```
# map to guest = bad user
```

Kéo xuống cuối file, tìm block [share] sửa lại như sau:

```
h4rrybrwnie@lan20-fileserver × + v
GNU nano 7.2 /etc/samba/smb.conf
# Windows clients look for this share name as a source of downloadable
# printer drivers
[print$]
    comment = Printer Drivers
    path = /var/lib/samba/printers
    browseable = yes
    read only = yes
    guest ok = no
# Uncomment to allow remote administration of Windows print drivers.
# You may need to replace 'lpadmin' with the name of the group your
# admin users are members of.
# Please note that you also need to set appropriate Unix permissions
# to the drivers directory for these users to have write rights in it
;   write list = root, @lpadmin

[share]
    path = /srv/share
    browseable = yes
    read only = no
    guest ok = no
    valid users = nhanvien
    create mask = 0600
    directory mask = 0700
```

Kiểm tra file cấu hình:

```
h4rrybrwnie@lan20-fileserver:~$ testparm
Load smb config files from /etc/samba/smb.conf
Loaded services file OK.
```

Data-in-Transit Encryption

```
sudo nano /etc/samba/smb.conf
```

thêm vào sau thẻ [global]:

```
server min protocol = SMB3
smb encrypt = required
```

```
[global]
server min protocol = SMB3
smb encrypt = required
## Browsing/Identification ###
```

```
sudo systemctl restart smbd
```

Kiểm tra xem Encryption đã hoạt động chưa:

PID	Username	Group	Machine	Protocol Version	Encryption	Signing
3165	nhavvien	nhavvien	192.168.40.10 (IPv4:192.168.40.10:53150)	SMB3_11	AES-128-GCM	partial(AES-128-GMAC)

8. LAN30 (EMPLOYEE COMPUTER)

Tạo và config LAN30

```
sudo nano /etc/netplan/01-netcfg.yaml
network:
  version: 2
  renderer: networkd
  ethernets:
    ens33:
      addresses: [192.168.40.10/24]
      routes:
        - to: default
          via: 192.168.40.1
      nameservers:
        addresses: [8.8.8.8, 1.1.1.1]
```

Cài smbclient

Bước 1: Cài gói SMB client:

```
sudo apt update
sudo apt install smbclient -y
```

Bước 2: Liệt kê các share trên File Server:

```
smbclient -L 192.168.30.10 -N
```

```
h4rrybrwnie@h4rrybrwnie:~$ smbclient -L 192.168.30.10 -N

      Sharename      Type      Comment
      -----
      print$         Disk      Printer Drivers
      share           Disk
      IPC$           IPC       IPC Service (lan20-fileserer)
SMB1 disabled -- no workgroup available
```

→ File Server (Samba) hoạt động tốt và Employees PC có thể truy cập.

Bước 3: Tạo thư mục mount:

```
sudo mkdir -p /mnt/share
```

Mount thư mục share

```
sudo mount -t cifs //192.168.30.10/share /mnt/share -o guest
```

9. LAN40 (WAZUH + ADMIN DESKTOP)

Tạo và config LAN40

Thực hiện lệnh đặt IP

```
sudo nano /etc/netplan/01-netcfg.yaml
network:
  version: 2
  renderer: networkd
  ethernets:
    ens33:
      addresses: [192.168.50.10/24]
      routes:
        - to: default
          via: 192.168.50.1
      nameservers:
        addresses: [8.8.8.8, 1.1.1.1]
```

Wazuh-Agents

Trên các VM Agents chạy lệnh này để cài Wazuh Agent (chạy trên tất cả các máy trong LAN10, LAN20, LAN30)

```
# IP của Admin VM
export WAZUH_MANAGER="192.168.50.10"

# Tải gói agent
```

```
curl -so wazuh-agent.deb "https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.7.0-1_amd64.deb"
```

Cài đặt agent và cấu hình manager IP

```
sudo WAZUH_MANAGER="$WAZUH_MANAGER" dpkg -i ./wazuh-agent.deb
```

Bật và khởi động agent

```
sudo systemctl enable --now wazuh-agent
```

```
sudo systemctl status wazuh-agent
```

Admin Desktop

Sau khi đã cấu hình đầy đủ các bước trên, tại LAN40, Admin Desktop có thể truy cập được Wazuh Dashboard để tiện theo dõi hệ thống.

